KIEU STUDIO · GITHUB RADAR · TẬP 44 · CHEAT SHEET

SkillSpector

Bộ quét bảo mật cho agent skill: quét trước khi cài, báo cáo kèm điểm rủi ro.

`github.com/NVIDIA/SkillSpector`

+1.191	25.794	Apache-2.0
sao trong 7 ngày · ≈ 170 sao/ngày · Trending không liệt kê 30 ngày	tổng sao · GitHub API	giấy phép · tạo 2026-03-21

SkillSpector (Apache-2.0, của NVIDIA) quét agent skill để tìm lỗ hổng và dấu hiệu độc hại: nhận thư mục, tệp, kho Git, URL hoặc zip; 71 mẫu lỗ hổng thuộc 17 nhóm; phân tích tĩnh cộng đánh giá LLM tùy chọn; tra cứu OSV.dev; điểm rủi ro 0-100; báo cáo terminal, JSON, Markdown, SARIF.

Cách hoạt động trong sáu bước

1. **Nạp skill** — thư mục, zip, Git, URL
2. **Phân tích tĩnh nhanh** — 71 mẫu lỗ hổng
3. **Đánh giá bằng LLM** — tùy chọn
4. **Tra cứu CVE** — OSV.dev, có chế độ offline
5. **Chấm điểm rủi ro** — từ 0 đến 100
6. **Báo cáo** — terminal, JSON, SARIF

Bắt đầu nhanh

```
# Cài bằng uv
uv tool install \
git+https://github.com/NVIDIA/skillspector.git

# Quét một thư mục skill
skillspector scan ./my-skill/

# Chỉ phân tích tĩnh
skillspector scan ./my-skill/ --no-llm

# Xuất báo cáo JSON
skillspector scan ./my-skill/ --no-llm \
--format json --output report.json

# Yêu cầu: Python 3.12 trở lên (uv hoặc pip), hoặc Docker; đánh giá LLM cần nhà cung cấp và khóa API
```

Bảng lệnh / tính năng chính

`skillspector scan <đích>`	quét thư mục, tệp, Git, URL, zip
`--no-llm`	chỉ phân tích tĩnh
`--format json --output f`	xuất báo cáo
`skillspector mcp`	chế độ MCP (cần extra mcp)
`docker run ... skillspector`	chạy không cần Python

Đà tăng trưởng



Hai mốc có thật: đầu cửa sổ và hôm nay, trục bắt đầu từ 0. Mức tăng do GitHub Trending báo cáo, không tự dựng lại lịch sử sao.

Vì sao có repo này

- Agent skill chạy với niềm tin ngầm và gần như không được kiểm duyệt.
- Tác giả nêu: trong tập con 31.132 skill, 26,1% có lỗ hổng và 5,2% có dấu hiệu độc hại (số liệu của tác giả).

Dùng vào việc gì

- Quét skill trước khi cài vào agent
- Gắn bước quét vào quy trình duyệt
- Xuất báo cáo SARIF cho công cụ bảo mật
- Chạy tĩnh hoàn toàn bằng --no-llm

Cần cân nhắc trước khi dùng

- Kết quả quét không đảm bảo skill an toàn tuyệt đối.
- Phần đánh giá bằng LLM cần khóa API của nhà cung cấp.
- Cài đặt tải thêm phần mềm mã nguồn mở bên thứ ba: xem giấy phép của chúng.
- Tỉ lệ 26,1% và 5,2% là số liệu của tác giả.

Nguồn: README của repo, https://github.com/NVIDIA/SkillSpector, https://docs.nvidia.com/skills/scanning-agent-skills. Tổng sao: GitHub API; mức tăng: GitHub Trending (số do Trending báo cáo), chụp 13/11/2026; sao đo sự chú ý, không đo chất lượng, hãy kiểm tra lại trước khi dùng. Tóm tắt bằng lời của Kieu Studio; lệnh sao nguyên văn từ README; không dùng logo hay ảnh chụp của bên thứ ba. **Công khai:** nội dung soạn với sự hỗ trợ của AI, giọng đọc và nhân vật trong video là AI. Không phải lời khuyên đầu tư, không phải sản phẩm được Kieu Studio bảo chứng. **kieu.app**